

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Reconnaissance

Unit 2 • Ethical Hacking (10-151-160)



Learning Outcomes

By the end of this unit, you will be able to:



Research target information online

Use search operators, public records, and OSINT platforms — and pivot from each result to the next query.



Gather information about specific targets

Profile named individuals and explain why that profile has attack value.



Explain the importance of attack surface

Argue why knowing your footprint is a defensive requirement, not an offensive luxury.



Stay inside the legal line

Distinguish reading what is published from accessing what is not.

Opening Discussion

Readings and homework

- Hack The Box and TryHackMe registration — everyone in?
- What did the invite challenge actually require you to do?
- What did you find most interesting?

Recent news

- Breaches, exploits, and zero-days this week
- New research or attacker trends — phishing, scams, campaigns
- Correlate one attack with a framework: where was the flaw?

Keep the framework habit going — every incident we discuss gets mapped before we move on.



LESSON 1

Reconnaissance Fundamentals

What Reconnaissance Is

The deliberate collection of information about a target, before you act on it.

- **Purposeful** — every query answers a question you decided to ask, not whatever autocomplete suggests.
- **Stealthy** — good reconnaissance leaves little or nothing in the target's logs.
- **Legal in its methods** — you collect what has been published. No extortion, no impersonation, no logging in.

The uncomfortable part

Most of this phase is invisible to the defender. There is no alert for someone reading your staff directory — which is why the defensive answer is to reduce what there is to find.

Passive vs. Active

Passive — you never touch the target

- Search engines, WHOIS, certificate transparency, breach data, social media, public filings
- The data comes from third parties who already collected it
- Produces nothing in the target's logs
- Generally lawful regardless of authorization

Active — you interact directly

- Port scans, banner grabs, zone transfer attempts, crawling their site
- The data comes from the target's own systems
- Lands in firewall, web, and IDS logs
- Requires written authorization — this is where scope matters

Know which one you are in: The same curiosity that is lawful on Monday is unauthorized access on Tuesday. The difference is whether packets left your machine for theirs.

Why We Do It

Reconnaissance measures what an organization has already published about itself.

- **Public footprint** — staff names, technologies, vendors, locations. Job postings name the exact stack.
- **Attack surface** — every point where entry could be attempted: hosts, apps, cloud storage, portals, and people.
- **Human weaknesses** — interests and habits that make a convincing pretext.
- **Watering holes** — third-party sites the target population visits. Compromise those, and they come to you.



SECURITY FOCUS

You cannot protect an asset you do not know you own. Forgotten subdomains, a 2019 marketing microsite, and a test box in someone's personal cloud account are all still yours.

Why it matters: The asset nobody remembers is the asset nobody patches.

What Public Information Looks Like

Information	Where it comes from	Why it matters
Names and roles	Directories, LinkedIn, press releases, document metadata	Builds the phishing target list
Domains and subdomains	Certificate transparency, DNS, crt.sh	Surfaces hosts never meant to be public
IP addresses	Registry records, DNS, Shodan and Censys	Defines what is actually in scope
Email format	One confirmed address reveals the convention	Turns a staff list into an account list
Vendors and tech	Case studies, job postings, HTTP headers	Tells you what exploits to research

Each row is harmless alone. The finding is what happens when you combine three of them.

LESSON 2

Searching Effectively



The Skill Under the Tools

- **Typing fluency** — unglamorous, but throughput is what produces findings.
- **Tab discipline** — open results in new tabs, keep the results page intact, group by line of inquiry.
- **Skimming** — headings, first sentences, bolded terms. Decide in seconds whether a page deserves real reading.
- **Knowing when to stop** — reconnaissance has no natural end. Scope and your report questions define it.

Where good answers live

Vendor documentation — authoritative and current

Stack Overflow — good for error messages, verify it

Wikipedia — read it for the bibliography, cite the sources

Primary sources — filings, advisories, standards

Pivot and Synthesize

Each result reshapes the next query. The finding lives in the combination, not the fragments.

- A vendor name in a job posting becomes a **technology query**.
- An author name in PDF metadata becomes a **people query**.
- A subdomain becomes a **service query** in Shodan or Censys.
- Email convention + staff list + a VPN portal = a **credential-stuffing plan** — and each piece alone was nothing.

LIVE DEMO

Pick a company from the class and pivot live — narrate every decision.

LESSON 3

Google Dorking



Operators That Still Work

Syntax is operator:term with no spaces around the colon. Power comes from combining them.

Operator	What it does	Example
"quotes"	Exact phrase match	"annual security report"
site:	Restrict to a domain	site:mstc.edu
filetype:	Restrict to a file extension	filetype:pdf
intitle:	Match words in the page title	intitle:"index of"
inurl:	Match text in the URL	inurl:admin
-term	Exclude a word	mustang -car
*	Wildcard for any word	"error code * overheating"

Google documents only six operators; intitle, inurl, intext, and the wildcard are undocumented but working.

Combining Operators

One operator narrows. Four operators isolate.

```
site:example.com filetype:pdf
site:example.com filetype:pdf intext:"internal use only"
intitle:"index of" inurl:backup -site:github.com
```

- Start broad, then add one operator at a time and watch the result count fall.
- Published documents are the highest-value target: they carry **metadata** — author, internal paths, software version.
- If a query suddenly returns nothing useful, suspect **retirement** before you suspect your syntax.

LIVE DEMO

Build one query live, adding an operator at a time.

Operators That Are Gone

Most Google-hacking material online predates a decade of changes. These no longer work:

- **cache:** — cached links were pulled in January 2024 and the operator was disabled that September. Use the **Wayback Machine** instead.
- **related:** retired in 2023; **link:** removed; **info:** replaced by Search Console.
- **numrange**, **daterange**, **author**, **group**, **msgid**: — gone with the features behind them.
- **The + operator** — removed in 2011. Quotation marks do that job now.

Read tutorials with suspicion

A 2022 article can still teach a 2011 operator. When a dork fails, check whether the operator survived before you debug your syntax.

The Google Hacking Database

A curated catalog of queries known to surface what organizations did not mean to publish.

- **Files containing juicy info** — configs, logs, and database dumps left web-accessible.
- **Sensitive directories** — directory listings left enabled.
- **Login portals** and **error messages** — admin interfaces and stack traces that leak versions.
- **Vulnerable devices** — printers and cameras indexed by accident.



SECURITY FOCUS

Reading an indexed page is not unauthorized access. Logging in with credentials you found, downloading a dump, or probing the host afterward is.

Why it matters: In this course you observe, document, and report — you never authenticate.

LESSON 4

OSINT Tooling



Search Engines for Practitioners

Different indexes see different internets. Learn what question each one answers.

Tool	What it indexes	The question it answers
Shodan	Internet-connected hosts and service banners	What are they exposing, and what version?
Censys	Internet-wide scans, strong certificate data	Same question, second opinion
crt.sh	Certificate transparency logs	What subdomains exist?
Hunter.io	Email addresses by domain	What is the address convention?
Have I Been Pwned	Known breach corpora	Where is password reuse likely?
WiGLE	Wireless networks and locations	What is broadcasting on site?

All passive: these services touched the target, you did not.

theHarvester

One of the oldest OSINT tools — emails, names, subdomains, and hosts for a domain, from many sources at once.

```
theHarvester -d example.com -b duckduckgo,crtsh,bing
theHarvester -d example.com -b all -l 500 -f report
```

- Gather **employee names** and email addresses, then derive the address convention.
- Perform a **subdomain search** and compare the output against crt.sh — neither one is complete.
- Modules break when a source changes its rate limiting. Expect it; use several sources.

LIVE DEMO

Run theHarvester against the lab domain and read the output together.

Frameworks and Link Analysis

Automate the collection

- **Recon-ng** — modular framework, Metasploit-style console, workspace database that persists
- **SpiderFoot** — one seed value, 200+ sources, automated breadth
- Trade-off: breadth produces noise you have to triage

See the relationships

- **Maltego** — entities as nodes, Transforms pull related data, connections become visible
- Free tier is capped enough to be a training license
- Worth it when the investigation is about people connected to companies connected to domains

On tool directories: OSINT Framework and people-search sites are worth a look, but many links are dead and broker data is uneven. Verify every finding against a second source.

Blue Team Use of the Same Tools

Investigating a suspicious message uses exactly the tools an attacker uses for recon.

- **Read the headers** — originating hosts, referrers, and the request path tell you where it really came from.
- **urlscan.io** — submit the URL and see what the page loads and contacts, without visiting it yourself.
- **Cisco Talos and VirusTotal** — is this sending infrastructure already known to be hostile?
- **GreyNoise** — is this scanning traffic internet-wide background noise, or aimed at us?

Same skill, both directions

The analyst who is good at reconnaissance is also the analyst who is fast at phishing triage. This is why these skills hire well on the blue team.

LIVE DEMO

Investigate a real suspicious message end to end.



LESSON 5

Defense, Ethics, and the Law

Defending Against Reconnaissance

You cannot block passive reconnaissance. You can shrink what it finds.

- **Run recon against yourself** on a schedule and treat the output as a work queue.
- **Inventory what you own** — subdomains, buckets, certificates, netblocks. Retire what you do not need.
- **Scrub document metadata** before publishing; disable directory listings; return generic errors.
- **Monitor certificate transparency** — catches forgotten deployments and lookalike phishing domains.



SECURITY FOCUS

robots.txt does not hide anything. It politely asks well-behaved crawlers to skip a path — and publishes a list of the paths you consider sensitive.

Why it matters: Attackers read robots.txt first, for exactly that reason.

Mapping to ATT&CK

MITRE ATT&CK treats Reconnaissance as its own tactic. Map your findings to it.

Technique	What it covers	What you did in this unit
T1589	Gather victim identity information	Names, emails, address convention
T1590	Gather victim network information	Domains, netblocks, DNS
T1591	Gather victim org information	Roles, vendors, business relationships
T1593	Search open websites and domains	Google dorking, social media
T1596	Search open technical databases	Shodan, Censys, crt.sh, WHOIS
T1595	Active scanning	The line you do not cross unscoped

A finding mapped to a technique is a finding a security program can act on.

Where the Legal Line Sits

- **Reading published information** — lawful. A search engine indexed it; you looked at it.
- **Using credentials you found** — unauthorized access under the CFAA and Wisconsin statute, however easy they were to find.
- **Unauthorized active scanning** — contact with their systems. Terms-of-service violation at minimum.
- **Aggregating personal data** — privacy obligations do not vanish because each piece was public.

"It was publicly accessible" is not a defense: People have been prosecuted for findings they reached through ordinary browsing. Being technically right about how you found it has not protected people who acted on it.

Hacking Back

Why it fails

- **Attribution is hard** — attacks route through compromised third parties
- The host you hit back is usually another victim — a small business, a hospital
- **Authority is not yours** — offensive response is reserved to government actors
- Scanning their infrastructure or logging into their panel is still unauthorized access

What you can do instead

- Collect and preserve evidence properly
- Block, contain, and eradicate
- Notify law enforcement
- Share indicators with the community

Discussion: when is it ok to hack back — and what would you count as hacking back?

The Rule for This Unit



SECURITY FOCUS

Finding an exposure and using it are different acts with very different legal weight. Every activity in this unit stops at observation: you document what is publicly visible, you record the query that found it, and you write the recommendation that would remove it. You do not authenticate, you do not download, and you do not scan anything outside an authorized scope.

Why it matters: If a dork surfaces something genuinely sensitive belonging to a real organization, bring it to me — do not pursue it.

This is the professional standard, not a classroom restriction — it is the same line on a paid engagement.

Demos in This Unit

What we will run together in class, in order:

- Pivot demo — one company name to a full picture, narrated.
- Google dorking — build a query one operator at a time.
- theHarvester — names, emails, and subdomains for the lab domain.
- Subdomain cross-check — crt.sh against the Harvester output.
- Phishing investigation — headers, urlscan.io, and reputation lookups.



LIVE DEMO

Students follow along on their own machines where the tool allows it.

Hands-On: Unit 2 Lab

Passive reconnaissance of domainalarm.net · no active scanning · document every source

- Registration details, name servers, and hosting from WHOIS and DNS.
- Subdomain enumeration through certificate transparency and public sources.
- Exposed services identified through Shodan or Censys — not by scanning.
- Any published documents, and what their metadata reveals.
- For every finding: the exact query or tool that produced it.



Reproducibility is the grading criterion — a finding you cannot re-derive is not a finding.

Unit 2 Assignment

A short professional write-up on three tools or concepts from this unit

- What each tool or concept does, and what question it answers.
- Your own screenshots or output demonstrating its use.
- The defensive implication — what a security team should do differently knowing it exists.
- Written for a reader who is technical but unfamiliar with the specific tool.



This is practice for the report writing that carries most of your grade in later units.

Key Takeaways



Reconnaissance is purposeful, stealthy, and uses only lawful methods.



Passive never touches the target; active does, and requires authorization.



Findings come from combining fragments, not from any single query.



Defenders shrink the footprint — you cannot protect what you forgot you own.



Reading what is published is lawful. Using what you find is where the line is.

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Questions?

Unit 2 • Reconnaissance

